FICHE 4 - AUTHENTIFIER LES UTILISATEURS

Reconnaître les utilisateurs pour pouvoir, ensuite, leur donner les accès nécessaires.

Avant toute utilisation des moyens informatiques, un utilisateur doit être doté d'un **identifiant qui lui est propre** et doit **s'authentifier** afin de permettre de contrôler son identité et ses accès aux données dont il a besoin.

Les mécanismes permettant de réaliser l'authentification des personnes sont catégorisés selon qu'ils font intervenir :

- **un facteur de connaissance** (ce que l'on sait), par exemple un mot de passe ;
- **un facteur de possession** (ce que l'on a), par exemple une carte à puce ;
- **un facteur inhérent** (ce que l'on est), par exemple une empreinte digitale ou une manière de frapper au clavier[11]. Pour rappel, le traitement de données biométriques visant à identifier un individu automatiquement et de manière unique à partir de ses caractéristiques physiques, physiologiques ou comportementales est un traitement de données sensibles donnant lieu à l'application de l'article 9 du RGPD[12].

L'authentification d'un utilisateur est qualifiée de **multifacteur** lorsqu'elle a recours à une combinaison **d'au moins deux** facteurs de catégories distinctes. Elle est dite **robuste** si elle repose sur un mécanisme cryptographique dont les paramètres et la sécurité sont jugés robustes (ex. : clé cryptographique).

Les précautions élémentaires

- **Définir un identifiant unique par utilisateur et interdire les comptes partagés** entre plusieurs utilisateurs. Dans le cas où l'utilisation d'identifiants génériques ou partagés est incontournable, exiger une validation de la hiérarchie, mettre en œuvre des moyens pour tracer les actions associées à ces identifiants et renouveler le mot de passe dès qu'une personne n'a plus besoin d'accéder au compte.
- **Respecter la recommandation de la CNIL[13] dans le cas d'une authentification des utilisateurs basée sur des mots de passe,** notamment en appliquant les règles suivantes :
  - **stocker uniquement l'empreinte des mots de passe, obtenue selon des techniques à l'état de l'art ;**
  - ne pas demander le renouvellement périodique des mots de passe pour les simples utilisateurs (au contraire des administrateurs) ;
  - obliger l'utilisateur à **changer**, dès sa première connexion, **tout mot de passe attribué automatiquement ou par un administrateur** lors de la création du compte ou d'un renouvellement du mot de passe ;

11 La biométrie comportementale (ex. : frappe au clavier) est moins mature que la biométrie physiologique (ex. : empreinte digitale).

12 En matière d'authentification sur le lieu de travail, cela se traduit par l'obligation, pour tout responsable de traitement souhaitant mettre en œuvre un tel traitement, de se conformer aux dispositions du règlement type relatif à l'accès par authentification biométrique sur les lieux de travail (voir « Le contrôle d'accès biométrique sur les lieux de travail », cnil.fr).

13 « Mots de passe : une nouvelle recommandation pour maîtriser sa sécurité », cnil.fr